

Private Key Compromised!!!

I Should Have Handled it Better ...

This article focuses on a solution to ensure secure communication between the network endpoints, even if the server's private key is compromised.

Nowadays, almost every business is managed and developed with the help of the internet, i.e., by using web applications. Cybercrimes have increased over time and web application hacking has become very common. This is the reason why a lot of effort is put into ensuring the security of these web applications.

Encryption of communication is an obvious security mechanism, as it protects its confidentiality when in transit. This article assumes you know the basics and the terminology for:

- Asymmetric encryption
- Symmetric encryption
- Web communication

For web applications, secure communication happens when every message is encrypted, which we call HTTPS. Figure 1 gives the schematic representation of how this happens between the server and the client.

It is clear from Figure 1 that secure communication is done by encrypting the communication using a symmetric key [KSymm]. To exchange the symmetric key between end points, asymmetric key encryption is used [KPub and KPriv]. This scheme is less likely to break, as only the server has a private key with it.

What if a private key is compromised?

From the above discussion, it is very clear that the essence of the security of communication over the web is the privacy of the server's private key. The symmetric key [KSymm from Figure 1] is generated and exchanged between the end points using an asymmetric key exchange method. This symmetric key is used for encrypting the communication when data is in transit. If this symmetric key is known to an attacker, the confidentiality is lost and an attacker can decrypt the complete communication between those end points.

The obvious question is: how will an attacker get hold of the symmetric key?

I agree that getting hold of this symmetric key is not possible if the attacker does not have the private key of the server. It can be seen in Figure 1 that if an attacker has a private key [KPriv], it can decrypt the symmetric key generated and exchanged between the endpoints. Remember, the symmetric key encrypted using a public key can only be decrypted by the corresponding private key.

The impact: An attacker now acts like a server to the client, and can interpret all the communication between

